

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Maven) · Generated 2026-06-11 · Source SHA: `61ed8c3` · Source: `pom.xml`

Summary

Metric	Count
Total CVEs found	80
CRITICAL -severity CVEs	16
HIGH -severity CVEs	50
MEDIUM -severity CVEs	13
LOW -severity CVEs	1
Dependencies with CVEs	9
Supply-chain alerts	3
Auto-remediated in this PR	8 items (version bumps + supply-chain removals)
Pending human review	1 (guava MAJOR_REVIEW)

Known-vulnerable dependencies — remediation status

Dependency	Version	Top CVE	CVSS	Severity	Fix version	Status
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.17.2	FIXED in PR
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2026-34479	7.5	HIGH	2.17.2	FIXED in PR
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	2.13.5	FIXED in PR
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	8.0.33	FIXED in PR
com.google.protobuf:protobuf-java	3.19.4	CVE-2022-3171	7.5	HIGH	3.21.7	FIXED in PR (dependencyManagement pin)
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	32.0.0-jre	MAJOR_REVIEW — see issue
com.fasterxml.jackson.core:jackson-annotations	2.9.0	CVE-2018-1000873	6.5	MEDIUM	2.13.5	FIXED in PR (dependencyManagement pin)
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.18.0	FIXED in PR
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.17.0	FIXED in PR

All CVEs — top entries

CVE	Dependency	CVSS	Severity	Status
CVE-2021-44228	log4j-core 2.14.1	10.0	CRITICAL	Fixed → 2.17.2
CVE-2021-45046	log4j-core 2.14.1	9.0	CRITICAL	Fixed → 2.17.2
CVE-2019-14379	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-14540	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-14892	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-14893	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-16335	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-16942	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-16943	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-17267	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-17531	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2019-20330	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2020-8840	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2020-9546	jackson-databind 2.9.8	9.8	CRITICAL	Fixed → 2.13.5
CVE-2023-22102	mysql-connector-java 8.0.30	8.3	HIGH	Fixed → 8.0.33
CVE-2020-36518	jackson-databind 2.9.8	7.5	HIGH	Fixed → 2.13.5
CVE-2022-3171	protobuf-java 3.19.4	7.5	HIGH	Fixed → 3.21.7
CVE-2023-2976	guava 24.1.1-jre	7.1	HIGH	MAJOR_REVIEW pending
CVE-2021-29425	commons-io 2.4	4.8	MEDIUM	Fixed → 2.18.0
CVE-2025-48924	commons-lang3 3.4	5.3	MEDIUM	Fixed → 3.17.0
(+60 more)	jackson-databind 2.9.8	various	HIGH	Fixed → 2.13.5

Supply-chain alerts

CRITICAL — Typosquatted dependency removed. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonated `com.fasterxml.jackson.core` ; coordinate does not exist on Maven Central. **Removed in this PR.**

HIGH — Untrusted HTTP repository removed. `http://insecure-mirror.example.net/maven2` plain-HTTP Maven repository (MITM artifact-injection risk). **Removed in this PR.**

MEDIUM — License violation (not auto-resolved). `mysql:mysql-connector-java` GPL-2.0 in a permissive-only project. Version bumped to 8.0.33 to clear CVE; license review requires human action — see tracking issue.